

Phase 17 — Security and No-Fake-Buttons Audit

Generated: 2026-05-07 21:19:41

Result

****PARTIAL GO with UI hygiene fixes applied.**** Gateway, Agent Hub, SpaceAgent browser automation, Paperclip bridge, and route-auth contracts passed targeted tests. The SpaceAgent browser automation button model is split into enabled read-only routes and Bridge Session-gated actions. Four legacy owner-facing strings that exposed runtime paths or ``.env`` wording were replaced with protected-runtime labels.

Fixes Applied

Area	Change
Build-Wiki card	Replaced raw destination fallback with owner-safe OpenClaw+ / Build-Wiki wording.
Viral Crawl page	Replaced visible config path with protected runtime config wording.
Viral Crawl command template	Replaced raw OpenClaw+ wrapper path with an owner-safe wrapper label.
Hermes runtime setup	Replaced visible auth/config path with protected Hermes runtime config wording.
GitHub dashboard widget	Replaced <code>`.env.local`</code> instruction with protected runtime settings wording.

Button Audit

Safe read-only SpaceAgent browser automation buttons map to real routes:

- Check Playwright MCP status: ``GET /api/bridge/playwright-mcp/status``
- Open last browser evidence packet: ``GET /api/gateway/space-agent/playwright-mcp/evidence``
- Run Mission Control UI smoke: ``POST /api/bridge/playwright-mcp/smoke``

Gated actions are disabled or Bridge Session-gated:

- Start browser session
- Interactive browser action
- Authenticated browsing
- Submit form
- Upload file

Route Auth Smoke

The following protected routes returned ****401**** without authentication:

- ``/api/gateway/status``

- `/api/gateway/agent-hub/status`
- `/api/gateway/nodes/space-agent`
- `/api/gateway/nodes/playwright-mcp`
- `/api/bridge/playwright-mcp/status`
- `/api/bridge/hermes/status`
- `/api/bridge/paperclip/status`

Tests Passed

- `src/lib/space-agent-browser-automation.test.ts`: 2 passed
- `src/lib/gateway-security-proof.test.ts`: 4 passed
- `src/lib/paperclip-bridge.test.ts`: 36 passed
- `src/lib/gateway-agent-hub.test.ts`: 3 passed
- `src/lib/gateway-route-auth.test.ts`: 1 passed
- Total targeted audit tests: 46 passed
- `pnpm run typecheck`: passed

Scan Results

- Targeted owner-facing raw path leaks after fix: 0.
- Remaining raw path matches exist in server/API implementation constants and legacy internals. They were not exposed by the targeted Agent Hub / SpaceAgent / Paperclip UI audit, but they should be covered by a broader API response redaction pass before any 100% claim.
- No staged secret values were introduced.
- No `.env` file was changed.

Security Confirmation

- No secrets printed.
- No auth files printed.
- No public local UI exposure added.
- No auth weakening.
- No external writes.
- No SMB/Fork 2.
- No Zapier writes.
- No HeyGen generation.
- No external farmers.
- OpenClaw+ naming is used for the runtime/skills/agents layer.

Remaining Blockers

- `owner\_authenticated\_browser\_session\_required`: visual owner-auth proof still pending.
- `broad\_api\_response\_redaction\_audit\_required`: internal API constants still include runtime paths; owner-facing responses need a dedicated redaction review before 100%.
- `active\_bridge\_session\_required`: gated actions remain intentionally disabled until scoped Bridge Session exists.

Next Step

Proceed to Phase 18: parked artifact cleanup classification.